

Scansione Iniziale BSides Vancouver 2018

28/07/2026

Obiettivo: Il presente report documenta i risultati della scansione di vulnerabilità iniziale condotta con Nessus sulla macchina virtuale BSides Vancouver 2018 (192.168.56.102), senza l'utilizzo di credenziali di accesso, la scansione ha identificato 28 elementi tra vulnerabilità reali e segnalazioni informative

1. Panoramica Risultati

La scansione ha rilevato complessivamente 28 elementi: 1 Critical, 2 Medium, 4 Low e 21 Info, la criticità più grave riguarda il sistema operativo Ubuntu 12.04 LTS in End of Life dal 2017, invece le due vulnerabilità Medium riguardano SSH e Apache, le 4 Low riguardano configurazioni crittografiche SSH e ICMP e le 21 Info includono rilevamenti di servizio, metadati di sistema e alcune segnalazioni da valutare come falsi positivi

Sev	CVSS	VPR	EPSS	Name	Family	Count
Critical	10.0			Canonical Ubuntu Linux SEOL (12.04.x)	General	1
Mixed				SSH (Multiple Issues)	Misc.	6
Mixed				Apache HTTP Server (Multiple Issues)	Web Servers	3
Low	2.1 *			ICMP Timestamp Request Remote Data Disclosure	General	1
Info				HTTP (Multiple Issues)	Web Servers	3
Info				SSH (Multiple Issues)	General	2
Info				SSH (Multiple Issues)	Service detection	2
Info				Nessus SYN scanner	Port scanners	3
Info				Service Detection	Service detection	3
Info				Backported Security Patch Detection (WWW)	General	1
Info				Common Platform Enumeration (CPE)	General	1
Info				Device Type	General	1
Info				Ethernet Card Manufacturer Detection	Misc.	1
Info				Ethernet MAC Addresses	General	1
Info				FTP Server Detection	Service detection	1
Info				mDNS Detection (Local Network)	Service detection	1
Info				Nessus Scan Information	Settings	1
Info				OpenSSH Detection	Misc.	1
Info				OS Fingerprints Detected	General	1
Info				OS Identification	General	1

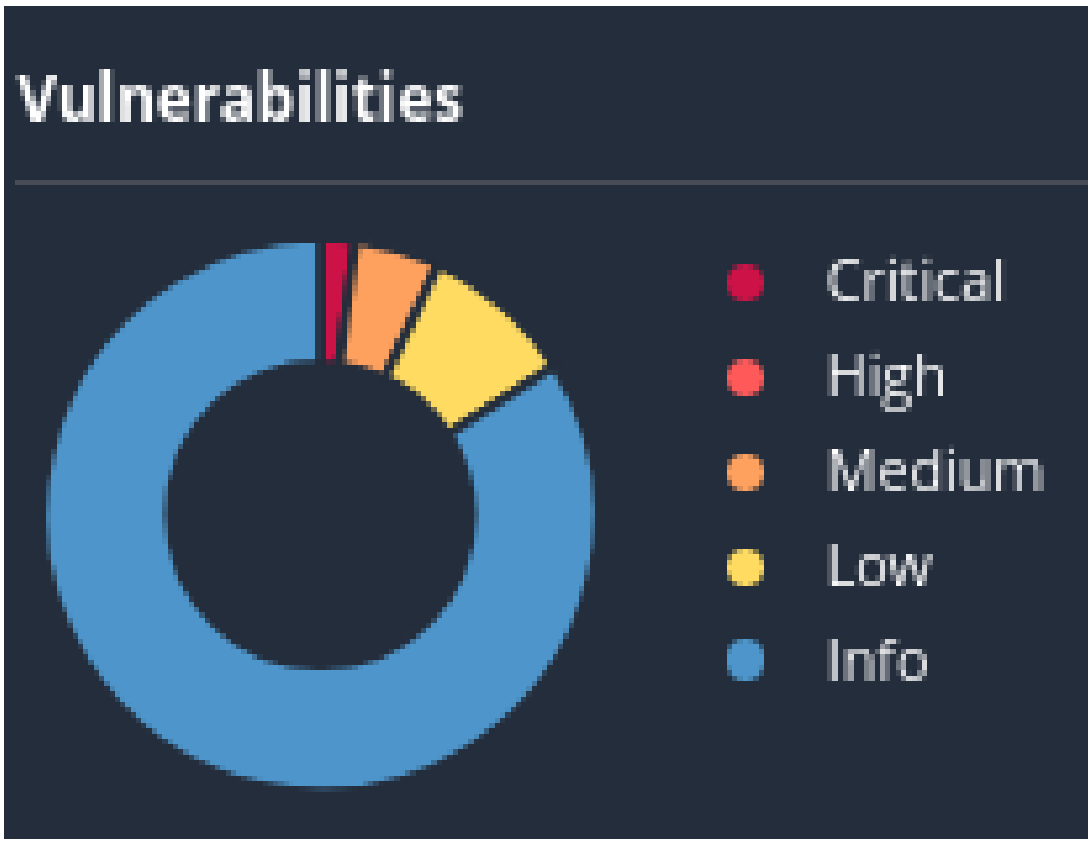


Fig. 2 — Grafico distribuzione severità: Critical (rosso), Medium (arancio), Low (giallo), Info (blu)

Fig. 1 — Riepilogo scansione — 28 vulnerabilità (Critical, Mixed SSH, Mixed Apache, Low ICMP)

Dettaglio: SSH e Apache — vulnerabilità Medium e Info

Sev	CVSS	VPR	EPSS	Name
Medium	4.3 *			SSH Weak Algorithms Supported
Low	3.7			SSH Server CBC Mode Ciphers Enabled
Low	3.7			SSH Weak Key Exchange Algorithms Enabled
Low	2.6 *			SSH Weak MAC Algorithms Enabled
Info				SSH Algorithms and Languages Supported
Info				SSH SHA-1 HMAC Algorithms Enabled

Fig. 3 — Gruppo SSH — 1 Medium (CVSS 4.3) + 3 Low (CVSS 3.7/3.7/2.6) + 2 Info

Sev	CVSS	VPR	EPSS	Name
Medium	5.3			Apache Server ETag Header Information Disclosure
Info				Apache Banner Linux Distribution Disclosure
Info				Apache HTTP Server Version

Fig. 4 — Gruppo Apache — 1 Medium (CVSS 5.3) + 2 Info su versione e distribuzione

2. Vulnerabilità Critical

CRITICAL

CVSS: 10.0

Canonical Ubuntu Linux 12.04.x — End of Life

Descrizione: *Sistema operativo fuori supporto*

Ubuntu 12.04 LTS ha raggiunto la fine del ciclo di vita (EOL) il 28 aprile 2017, da quella data non riceve più aggiornamenti di sicurezza da Canonical e il sistema espone quindi tutte le vulnerabilità note del kernel 3.11.0-15, di OpenSSH 5.9p1, Apache 2.2.22 e vsftpd 2.3.5 successivamente scoperte — incluse quelle sfruttabili per privilege escalation locale, come dimostrato nel Report 2

Impatto: *Compromissione completa del sistema*

Un sistema EOL privo di patch è vulnerabile a exploit noti e pubblicamente disponibili per ogni componente software installato. In questo caso il kernel 3.11 (CVE-2016-9793 e simili), i servizi esposti (SSH, FTP, Apache, MySQL) e le configurazioni di sistema non aggiornate rappresentano una superficie di attacco molto ampia. Durante il pentest è stata ottenuta una shell root sfruttando configurazioni lasciate vulnerabili sul sistema EOL.

3. Vulnerabilità Medium

MEDIUM

CVSS: 4.3

SSH Weak Algorithms Supported

Descrizione: *OpenSSH 5.9p1 supporta algoritmi crittografici deboli*

Il server SSH supporta: cifrari CBC (vulnerabili a Lucky13/SWEET32), algoritmi di scambio chiave deprecati (diffie-hellman-group1-sha1, curve basate su NIST P-256 con potenziali debolezze), e algoritmi MAC basati su SHA-1 (deprecato da NIST dal 2011), questi permettono potenziali attacchi di downgrade su connessioni SSH

Hosts	1	Vulnerabilities	28	Notes	2	History	1
Search Vulnerabilities							6 Vulnerabilities
☐	Sev	CVSS	VPR	EPSS	Name		
☐	MEDIUM	4.3 *			SSH Weak Algorithms Supported		
☐	LOW	3.7			SSH Server CBC Mode Ciphers Enabled		
☐	LOW	3.7			SSH Weak Key Exchange Algorithms Enabled		
☐	LOW	2.6 *			SSH Weak MAC Algorithms Enabled		
☐	INFO				SSH Algorithms and Languages Supported		
☐	INFO				SSH SHA-1 HMAC Algorithms Enabled		

Fig. 5 — Nessus — gruppo SSH: 1 Medium (4.3) + 3 Low + 2 Info

```
(kali@kali)~[~/Desktop]
$ sudo nmap -p 21,22,80 -Pn -n -sT -sV -sC 192.168.56.102

Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-24 14:36 -0400ed, yet.
Nmap scan report for 192.168.56.102
Host is up (0.00062s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
| ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 192.168.56.101
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 3
|_    vsFTPd 2.3.5 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 65534  65534   4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protoco
l 2.0)
| ssh-hostkey:
|_  1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_ 2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_ 256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
```

Fig. 6 — nmap -sV — OpenSSH 5.9p1 su porta 22 (Ubuntu 12.04)

MEDIUM

CVSS: 5.3

Apache Server ETag Header Information Disclosure

Descrizione: *Apache 2.2.22 espone informazioni di filesystem tramite ETag*

Apache, nella configurazione di default, include negli header HTTP ETag informazioni sul filesystem: numero di inode, dimensione file e timestamp di ultima modifica, queste informazioni, invisibili all'utente finale, facilitano attività di fingerprinting e ricognizione dell'infrastruttura da parte di un attaccante

Hosts	1	Vulnerabilities	28	Notes	2	History	1
Search Vulnerabilities							3 Vulnerabilities
☐	Sev	CVSS	VPR	EPSS	Name		
☐	MEDIUM	5.3			Apache Server ETag Header Information Dis		
☐	INFO				Apache Banner Linux Distribution Disclosu		
☐	INFO				Apache HTTP Server Version		

Fig. 3 — Nessus — gruppo Apache: 1 Medium (5.3) + 2 Info

☐	INFO	OS Security Patch Assessment Not Available
☐	INFO	Remote Services Not Using Post-Quantum Ciphers
☐	INFO	Shor's Harvest Now Decrypt Later
☐	INFO	Target Credential Status by Authentication Protocol - No Credentials Prov
☐	INFO	TCP/IP Timestamps Supported
☐	INFO	Traceroute Information
☐	INFO	vsftpd Detection
☐	INFO	Web Server robots.txt Information Disclosure

Fig. 4 — Nessus — resto scansione iniziale: Low ICMP + 21 Info

4. Vulnerabilità Low

LOW

CVSS: 3.7

SSH Server CBC Mode Ciphers Enabled

I cifrari CBC (aes128-cbc, 3des-cbc, ecc.) sono vulnerabili all'attacco Lucky13, un attaccante in grado di intercettare il traffico potrebbe in teoria decifrare parti della comunicazione

LOW

CVSS: 3.7

SSH Weak Key Exchange Algorithms Enabled

Algoritmi di scambio chiave deprecati abilitati (diffie-hellman-group-exchange-sha1, diffie-hellman-group1-sha1), questi hanno lunghezze di chiave insufficienti per gli standard crittografici attuali

LOW

CVSS: 2.6

SSH Weak MAC Algorithms Enabled

Algoritmi MAC basati su MD5 e SHA-1 abilitati, MD5 è crittograficamente rotto, SHA-1 è deprecato, quindi un attaccante potrebbe teoricamente alterare messaggi non rilevando la manomissione

LOW

CVSS: 2.1

ICMP Timestamp Request Remote Date Disclosure

Il sistema risponde ai pacchetti ICMP Timestamp (tipo 13/14) rivelando data e ora del sistema, un attaccante può usare queste informazioni per sincronizzare attacchi temporizzati o fingerprinting.

5. Rilevamenti Info — Servizi e Metadati di Sistema

I 21 rilevamenti Info non rappresentano vulnerabilità direttamente sfruttabili ma forniscono informazioni sul sistema. Tra i principali:

- **FTP Server Detection:** vsftpd 2.3.5 attivo su porta 21 — accesso anonimo abilitato
- **OpenSSH Detection:** OpenSSH 5.9p1 su porta 22
- **Apache HTTP Server Version:** Apache 2.2.22 su porta 80
- **OS Identification / OS Fingerprints:** Ubuntu 12.04 LTS — Linux kernel 3.11
- **Ethernet MAC Addresses:** MAC del target: 08:00:27:07:5f:6a (VirtualBox)
- **Web Server robots.txt Information Disclosure:** robots.txt espone esplicitamente il path /backup_wordpress
- **Backported Security Patch Detection (WWW):** Ubuntu/Debian applicano backport — alcune versioni potrebbero risultare false positive
- **Remote Services Not Using Post-Quantum Ciphers:** Avviso teorico su futura minaccia quantistica — vedi sezione Falsi Positivi nel Report 2
- **Shor's Harvest Now Decrypt Later:** Avviso teorico: traffico attuale potrebbe essere decifrato da computer quantistici futuri
- **Target Credential Status — No Credentials Provided:** Scansione eseguita senza credenziali — alcune vulnerabilità potrebbero non essere state rilevate